Phishing Email Investigation

"Microsoft account unusual signin activity"

Analyst	Tushar Mishra
Report date	2 November 2026
Sample	`sample-10.eml` from the public phishing_pot corpus (github.com/rf-peixoto/phishing_pot)
Environment	Kali Linux VM; the sample was read as plain text only and no URL was visited

1. Summary

Verdict	**Malicious**: a spoofed Microsoft security alert that is part of a larger phishing campaign
Confidence	**High** that the email is malicious. **Medium** on its exact purpose (callback lure with open tracking; no credential-harvesting page was observed)
Email date	Fri, 8 Sep 2023, 05:47:04 UTC
Subject	Microsoft account unusual sign-in activity

Key evidence

1. The display name says "Microsoft account team", but the From domain (`access-acc-security[.]com`), the Return-Path domain (`thcultarfdes[.]co[.]uk`) and the Reply-To (a Gmail address) are three unrelated identities.
2. SPF = none, DKIM = none, DMARC = permerror, and the From domain is not a Microsoft domain.
3. A hidden 1x1 tracking pixel loads from `thebandalisty[.]com`, which 9 of 92 VirusTotal vendors flag as phishing or malicious.
4. Every `mailto:` link in the body leads to the same attacker-controlled Gmail address.
5. The indicators recur across the phishing_pot corpus: the sender domain in 108 emails, the Gmail address in 56, the tracking domain in 217, and the sending IP in the headers of 26 samples.
6. A large block of unrelated random word lists is appended to the body, consistent with spam-filter evasion.

Recommended actions: block the indicators in section 8, search mailboxes and proxy logs for matches, and reset credentials for anyone who replied (section 10).

2. Scope, source and method

- **Source:** the sample comes from the public phishing_pot corpus. It is a real-world phishing email, not one I received. Other public write-ups of this sample exist; the analysis and screenshots here are from my own lookups.
- **Handling:** the `.eml` file was only read as text (`sed`, `grep`, `less`). I did not open it in a mail client or browser and I did not visit any URL, so the tracking pixel never loaded.
- **Tools:** command-line header inspection, `whois`, `dig`, VirusTotal, AbuseIPDB, CyberChef (Extract URLs, Extract email addresses) and a short Python script to search the corpus.

- **Timing:** lookups were made on 27 October and 2 November 2026, more than three years after the email. Most of the infrastructure no longer exists, so current data often differs from 2023 data (see section 11).
- **Defanging:** every indicator in this report is defanged (`hxxp`, `[.]`).

3. Email overview

Field	Value
From	`Microsoft account team <no-reply@access-accsecurity[.]com>` (header is malformed)
Return-Path	`bounce@thcultarfdes[.]co[.]uk`
Reply-To	`sotrecognizd@gmail[.]com`
To	`phishing@pot`
Subject	Microsoft account unusual signin activity
Date	Fri, 8 Sep 2023 05:47:04 +0000
Priority	Importance: high, X-Priority: 1, X-Message-Flag: Flag
Content-Type	text/html; charset=UTF-8
Attachments	None (0)
Links	One remote image (tracking pixel) and three `mailto:` links

4. Header analysis

4.1 Sender identity mismatch

The sender shows three different identities:

Header	Value	Observation
From	`no-reply@access-accsecurity[.]com`	Lookalike of a Microsoft security sender; genuine Microsoft account alerts do not come from this domain
Return-Path	`bounce@thcultarfdes[.]co[.]uk`	Unrelated domain
Reply-To	`sotrecognizd@gmail[.]com`	Free-mail address; a real Microsoft alert would not ask for replies to Gmail

The email also carries two `Content-Length` headers with different values (18708448 and 1821750), which a normal mail server would not produce. Both numbers reappear inside the tracking URL (section 5.2), which is consistent with templated per-message tokens.

```
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
To: phishing@pot
Content-Length: 18708448
Content-Length: 1821750
Date: Fri, 8 Sep 2023 05:47:04 +0000
Reply-To: sotrecognizd@gmail.com
Content-Type: text/html; charset="UTF-8"
Content-Transfer-Encoding: 8bit
X-IncomingHeaderCount: 12
Message-ID:
 <032672b4-77ca-42f8-a036-9711e91bd1f3@DB8EUR06FT032.eop-eur06.prod.protection.outlook.com>
Return-Path: bounce@thcultarfdes.co.uk
```

Figure 1. From, Subject, duplicate Content-Length, Reply-To and Return-Path headers.

4.2 Authentication results

```
spf=none (sender IP is 89.144.44.2) smtp.mailfrom=thcultarfdes.co.uk
dkim=none (message not signed)
dmarc=permerror action=none header.from=access-accsecurity.com
Received-SPF: None (thcultarfdes.co.uk does not designate permitted sender hosts)
```

- **SPF none:** the Return-Path domain publishes no SPF record that authorises the sending IP. The check ran against the Return-Path domain, not the From domain.
- **DKIM none:** the message is unsigned.
- **DMARC permerror:** the policy for the From domain could not be evaluated; this is not a pass.
- Microsoft recorded SCL 5 and BCL 6 for the message.

```
 Transport; Fri, 8 Sep 2023 05:47:04 +0000
Authentication-Results: spf=none (sender IP is 89.144.44.2)
 smtp.mailfrom=thcultarfdes.co.uk; dkim=none (message not signed)
 header.d=none;dmarc=permerror action=none header.from=access-accsecurity.com;
Received-SPF: None (protection.outlook.com: thcultarfdes.co.uk does not
 designate permitted sender hosts)
Received: from thcultarfdes.co.uk (89.144.44.2) by
 DB8EUR06FT032.mail.protection.outlook.com (10.233.253.34) with Microsoft SMTP
 Server id 15.20.6768.30 via Frontend Transport; Fri, 8 Sep 2023 05:47:04
 +0000
```

Figure 2. Authentication-Results and Received-SPF lines, plus the originating hop.

4.3 Received chain

Reading the `Received` lines from bottom to top, the oldest hop is:

```
from thcultarfdes.co.uk (89.144.44.2) by DB8EUR06FT032.mail.protection.outlook.com
(10.233.253.34) ... Fri, 8 Sep 2023 05:47:04 +0000
```

This confirms the originating server as `thcultarfdes[.]co[.]uk` at **89[.]144[.]44[.]2** (also shown in `X-Sender-IP`). The remaining hops are internal Microsoft Exchange Online servers.

```
┌──(kali㉿kali)-[~/phishing-investigation/samples]
└─$ sed -n '1,/^$/p' sample-10.eml
Received: from SJ0PR19MB6679.namprd19.prod.outlook.com (::1) by
 MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Fri, 8 Sep 2023 05:47:06
 +0000
Received: from DB8P191CA0014.EURP191.PROD.OUTLOOK.COM (2603:10a6:10:130::24)
 by SJ0PR19MB6679.namprd19.prod.outlook.com (2603:10b6:a03:477::19) with
 Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6768.30; Fri, 8 Sep
 2023 05:47:04 +0000
Received: from DB8EUR06FT032.eop-eur06.prod.protection.outlook.com
 (2603:10a6:10:130:cafe::9b) by DB8P191CA0014.outlook.office365.com
 (2603:10a6:10:130::24) with Microsoft SMTP Server (version=TLS1_2,
 cipher=TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384) id 15.20.6768.30 via Frontend
 Transport; Fri, 8 Sep 2023 05:47:04 +0000
Authentication-Results: spf=none (sender IP is 89.144.44.2)
 smtp.mailfrom=thcultarfdes.co.uk; dkim=none (message not signed)
 header.d=none;dmarc=permerror action=none header.from=access-accsecurity.com;
Received-SPF: None (protection.outlook.com: thcultarfdes.co.uk does not
 designate permitted sender hosts)
Received: from thcultarfdes.co.uk (89.144.44.2) by
 DB8EUR06FT032.mail.protection.outlook.com (10.233.253.34) with Microsoft SMTP
 Server id 15.20.6768.30 via Frontend Transport; Fri, 8 Sep 2023 05:47:04
 +0000
X-IncomingTopHeaderMarker:
 OriginalChecksum:6DB22130536EEE635A126CD816D1A4DDD37580CD58231D7469764E41AA1094BF;UpperCasedChecksum:
```

Figure 3. Header section of sample-10.eml showing the Received chain.

5. Body analysis

5.1 mailto links

The body shows the text “Unusual sign.in activity” (a dot in “sign.in”, a common filter-evasion trick) and the recipient address as link text. The link actually points to the attacker’s mailbox. Three variants exist, all to the same address:

- subject “Report The User”
- subject “unusual signin activity” with body “Report The User”
- subject “Unsubscribe me”

The lure is designed to make the victim contact the attacker.

```
┌──(kali㉿kali)-[~]
└─$ cd ~/phishing-investigation/samples
grep -o 'href="mailto[^"]*"' sample-10.eml
href="mailto:sotrecognizd@gmail.com?&amp;cc=sotrecognizd@gmail.com&amp;Subject=Report+The+User"
href="mailto:sotrecognizd@gmail.com?&amp;cc=sotrecognizd@gmail.com&amp;subject=unusual signin activity&amp;body=Report The User"
href="mailto:sotrecognizd@gmail.com?&amp;cc=sotrecognizd@gmail.com&amp;Subject=Unsubscribe+me"

┌──(kali㉿kali)-[~/phishing-investigation/samples]
└─$
```

Figure 4. The three mailto links, all to sotrecognizd@gmail[.]com.

5.2 Tracking pixel

```
<img alt=""
src="hxxp://thebandalisty[.]com/track/o43062rdzGz18708448Gdrw1821750fYo33632dSjh176"
     width="1px" height="1px" style="visibility:hidden">
```

This is a hidden 1x1 remote image over plain HTTP. When a mail client loads it, the sender’s server logs the request, which confirms the mailbox is active and exposes the recipient’s IP address and client. The token in the path appears to be unique to the message. No other URL and no attachment was found.

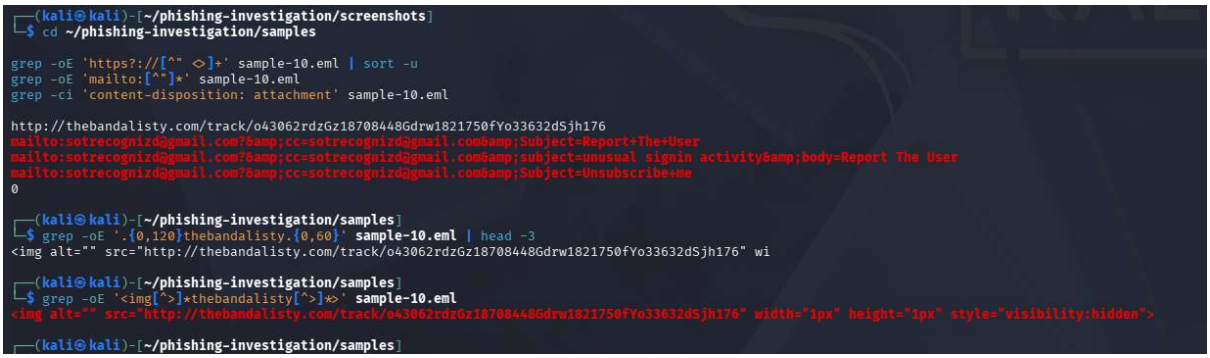


Figure 5. grep results: one URL, three mailto links, zero attachments, and the pixel tag.

I used CyberChef to confirm the extraction:

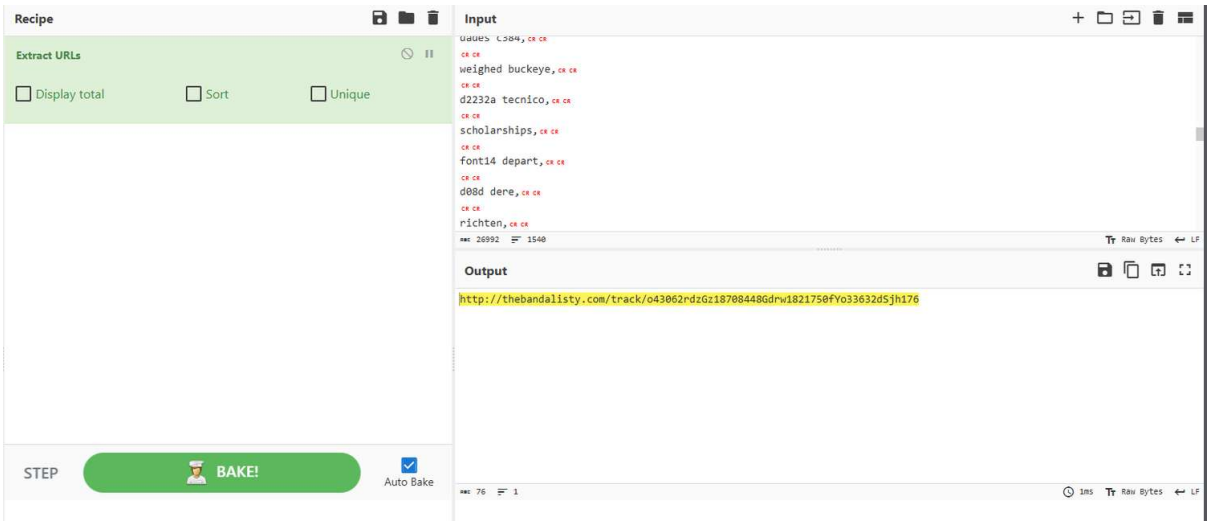


Figure 6. CyberChef Extract URLs on the email body.

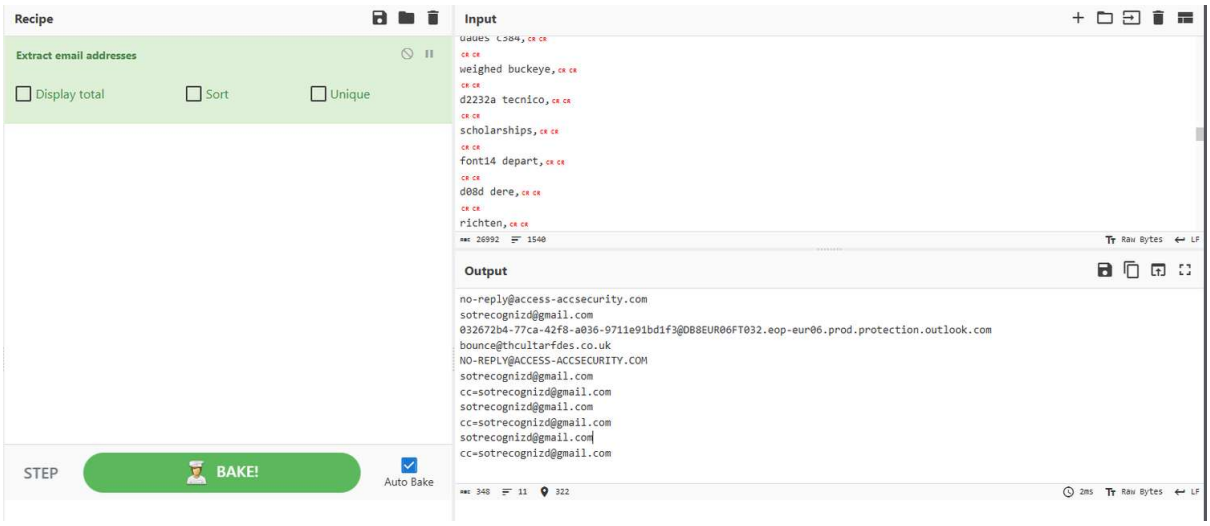


Figure 7. CyberChef Extract email addresses.

5.3 Filler text

The body file (`body.txt`) is 25,453 bytes. Its end consists of unrelated random word lists in several languages, with no connection to the alert text. This is consistent with padding added to dilute spam filters. I reviewed the end of the file only.



Figure 8. Size of body.txt and the end of the file, showing unrelated word lists.

6. Infrastructure analysis

6.1 access-accsecurity[.]com (From domain)

Item	Finding
WHOIS creation (VirusTotal)	2023-07-02, registrar NameBright, registrant details behind a privacy service
Detections	0/92 on VirusTotal
Last DNS records seen	A records in AWS ranges (`44[.]194[.]110[.]133`, `34[.]193[.]241[.]188`), a CNAME to `expired.namebright[.]com`, registrar-default MX and an SPF record listing only NameBright servers

The AWS addresses may be parking or redirect infrastructure; I did not attribute them to the attacker, and the date of that DNS snapshot is unknown.

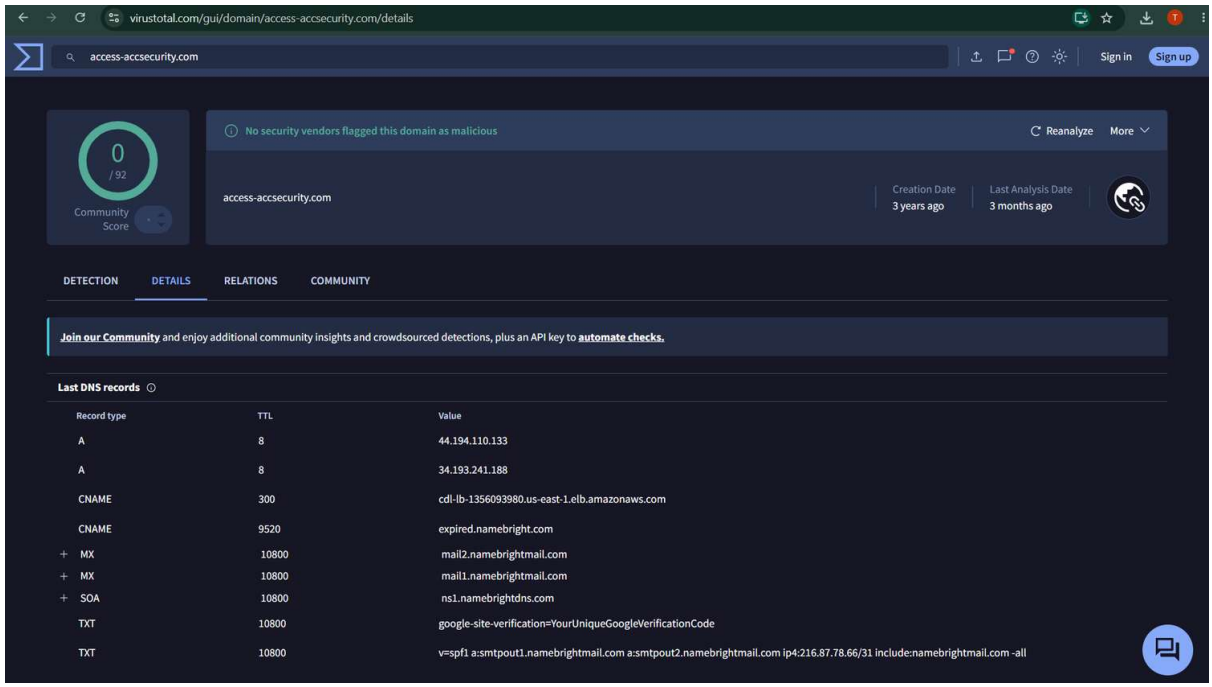


Figure 9. VirusTotal: 0/92 detections, creation date 3 years ago, last DNS records.

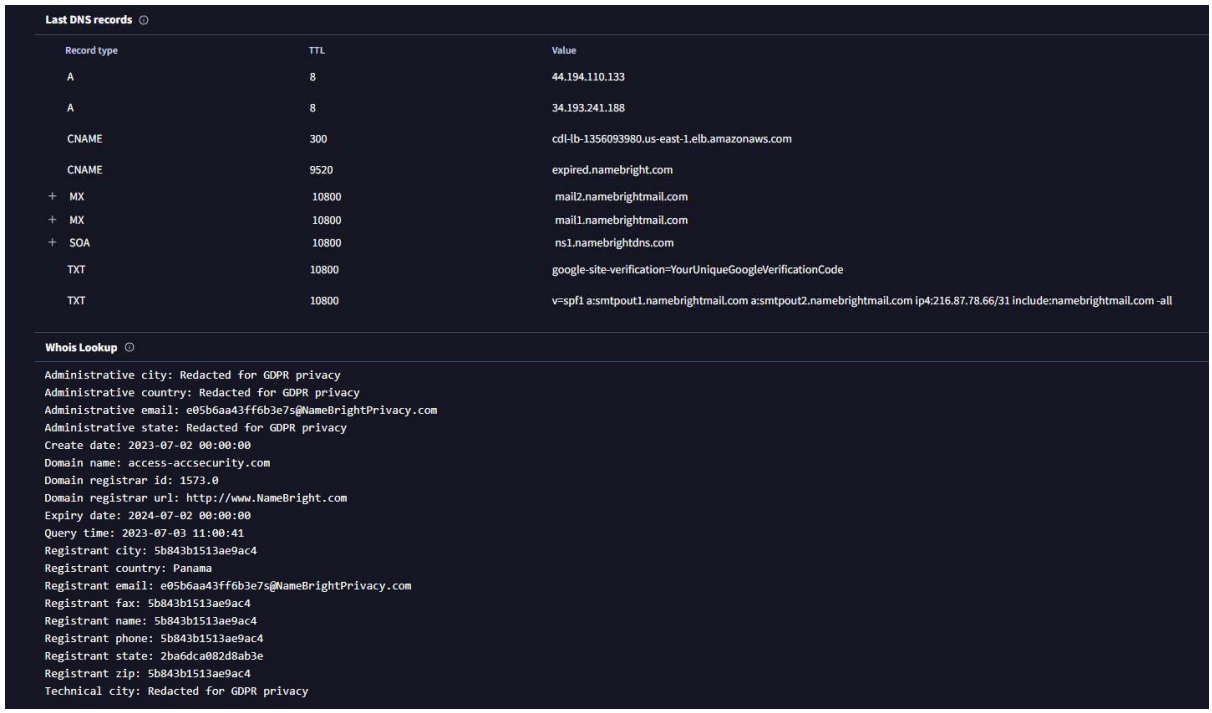


Figure 10. VirusTotal details: DNS records and WHOIS (created 2023-07-02).

Registration timing is unresolved. Microsoft's own timestamps show emails using this From domain arriving from **22 March 2023**, 102 days before the WHOIS creation date of 2 July 2023. I checked three corpus samples; the `Received` timestamps match their `Date:` headers to the second:

Sample	Received (Microsoft)	Date header
sample-498	22 Mar 2023 20:46:22	22 Mar 2023 20:46:22
sample-754	2 Jun 2023 22:14:31	2 Jun 2023 22:14:31

Sample	Received (Microsoft)	Date header
sample-856	3 Jul 2023 09:03:45	3 Jul 2023 09:03:45

Either the domain was registered earlier, lapsed and was re-registered on 2 July (which resets the creation date), or the attackers used a From domain that was not registered at all. The data cannot tell these apart, so I do not state the domain's age at the time of sending.

```
Session  Actions  Edit  View  Help
== sample-498.eml
 MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Wed, 22 Mar 2023 20:46:25
 Transport; Wed, 22 Mar 2023 20:46:22 +0000
 SMTP Server id 15.20.6222.17 via Frontend Transport; Wed, 22 Mar 2023
Date: Wed, 22 Mar 2023 20:46:22 +0000
X-MS-Exchange-Organization-ExpirationStartTime: 22 Mar 2023 20:46:22.8343
X-MS-Exchange-CrossTenant-OriginalArrivalTime: 22 Mar 2023 20:46:22.8186
== sample-754.eml
 DM4PR19MB6317.namprd19.prod.outlook.com with HTTPS; Fri, 2 Jun 2023 22:14:34
 Transport; Fri, 2 Jun 2023 22:14:31 +0000
 Server id 15.20.6477.10 via Frontend Transport; Fri, 2 Jun 2023 22:14:31
Date: Fri, 2 Jun 2023 22:14:31 +0000
X-MS-Exchange-Organization-ExpirationStartTime: 02 Jun 2023 22:14:31.6359
X-MS-Exchange-CrossTenant-OriginalArrivalTime: 02 Jun 2023 22:14:31.3235
== sample-856.eml
 MN0PR19MB6312.namprd19.prod.outlook.com with HTTPS; Mon, 3 Jul 2023 09:03:48
 Transport; Mon, 3 Jul 2023 09:03:45 +0000
 SMTP Server id 15.20.6565.17 via Frontend Transport; Mon, 3 Jul 2023 09:03:45
Date: Mon, 3 Jul 2023 09:03:45 +0000
X-MS-Exchange-Organization-ExpirationStartTime: 03 Jul 2023 09:03:45.7550
X-MS-Exchange-CrossTenant-OriginalArrivalTime: 03 Jul 2023 09:03:45.7082
```

Figure 11. Received and Date timestamps for sample-498, sample-754 and sample-856.

6.2 thcultarfdes[.]co[.]uk (Return-Path and sending host)

- WHOIS on 27 Oct 2026: "This domain name has not been registered."
- VirusTotal: 0/92.
- The domain no longer exists, so registration data from 2023 is not available.

```
┌──(kali㉿kali)-[~]
└─$ whois thcultarfdes.co.uk | head

   No match for "thcultarfdes.co.uk".

   This domain name has not been registered.

   WHOIS lookup made at 07:28:00 27-Oct-2026

   ********************************************************************************
   * WHOIS service for .UK will cease on 9th of February 2027                     *
   * For more information on the replacement RDAP services please see:            *
```

Figure 12. WHOIS lookup for thcultarfdes[.]co[.]uk: not registered.

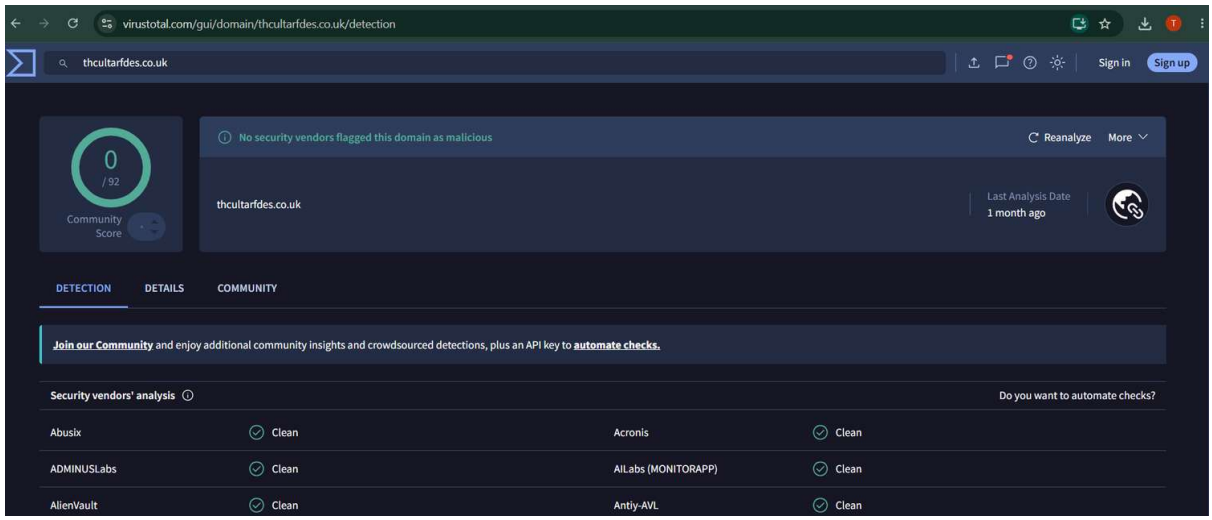


Figure 13. VirusTotal: 0/92 detections for thcultarfdes[.]co[.]uk.

6.3 thebandalisty[.]com (tracking pixel host)

Item	Finding
Created	2023-02-21, registrar NameCheap (about 199 days before the email)
Expired	2025-02-21; later seen in `redemptionPeriod`
Now	Not registered; `whois` returns no match and `dig` returns nothing
VirusTotal	**9/92** (7 phishing: alphaMountain.ai, BitDefender, Fortinet, G-Data, Lionic, Sophos, VIPRE; 2 malicious: CRDF, Webroot; ESET also lists it as suspicious)
Last DNS seen	Pointed at a domain-parking service (CNAME to `77980.bodis[.]com`)

These detections reflect VirusTotal's view at the time of checking and do not by themselves show that the domain was flagged in 2023. The corpus shows it was used in 217 emails between February 2023 and February 2024 (section 7).



Figure 14. whois and dig for thebandalisty[.]com: no match, no DNS answer.

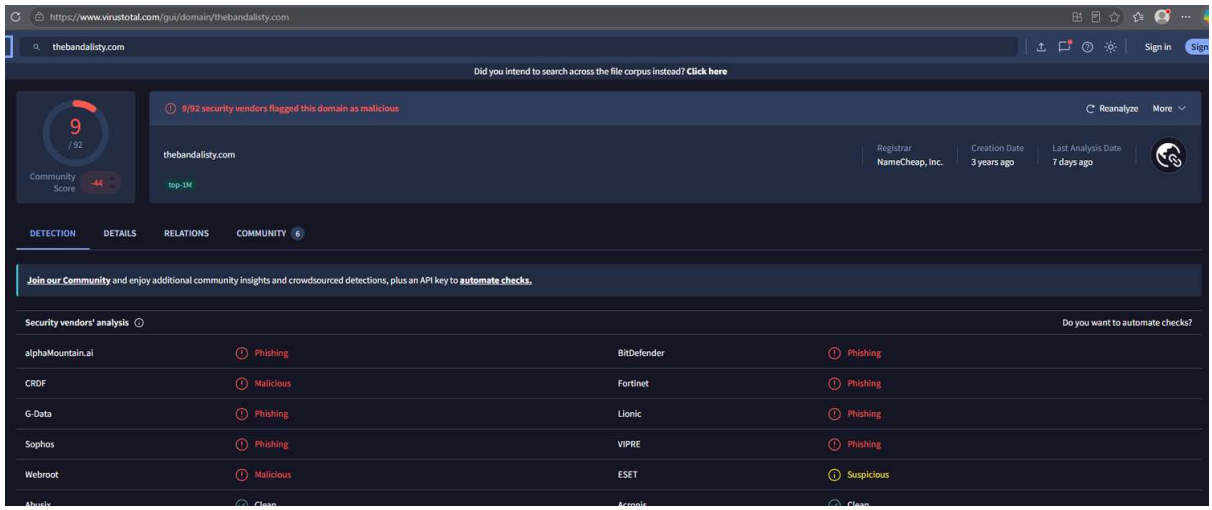


Figure 15. VirusTotal: 9 of 92 vendors flag thebandalisty[.]com.

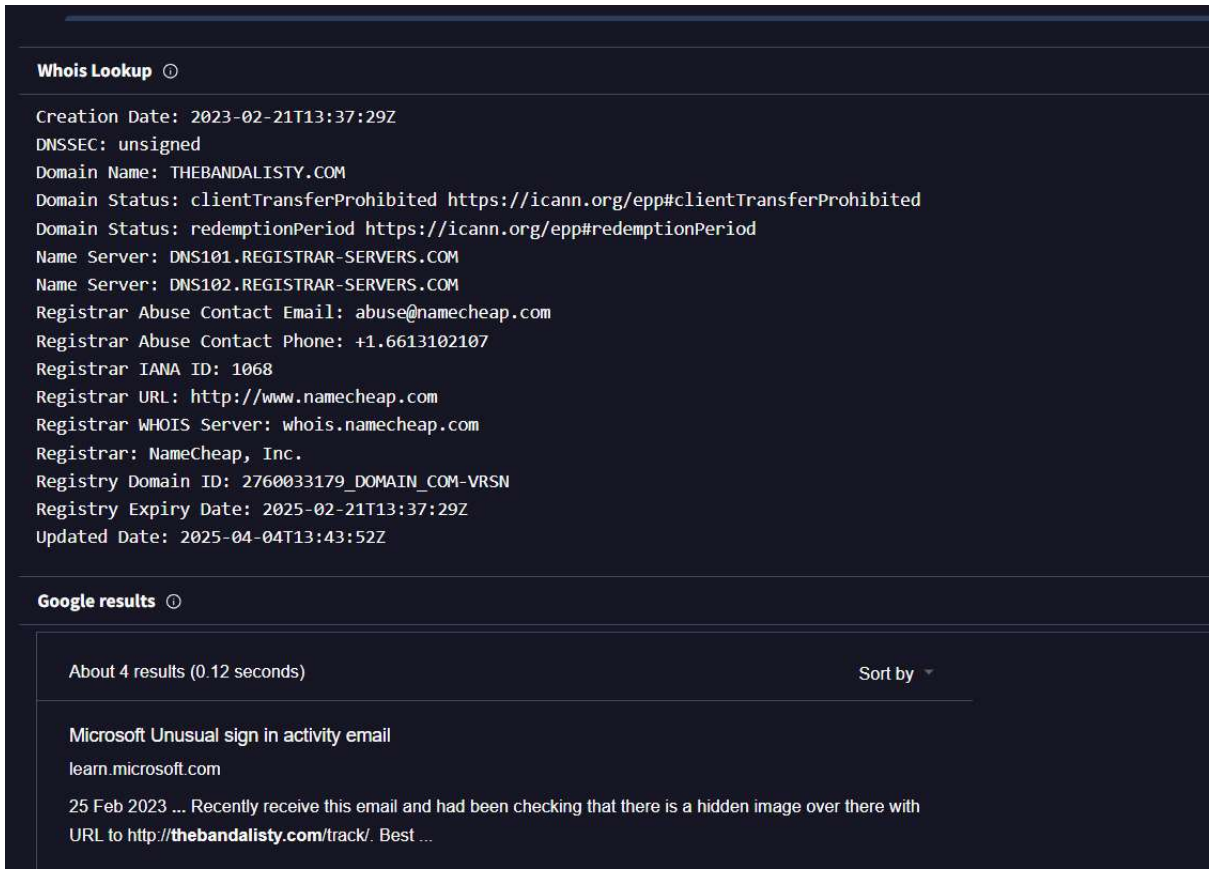


Figure 16. VirusTotal WHOIS: created 2023-02-21 via NameCheap.

6.4 89[.]144[.]44[.]2 (sending IP)

Item	Finding
Role	Delivered the email to Microsoft (Received chain, `X-Sender-IP`)
Current holder (RIPE)	MSCode, Poland; range `89[.]144[.]44[.]0/24`, allocation created **2026-02-14**; origin AS201132
AbuseIPDB	0% confidence; 1 report (2026-09-06, port scan)
VirusTotal	0/92; 2 communicating files, both Windows executables scanned in 2014 and 2015

Item	Finding
Passive DNS	59 records, including other parties' sites in 2019-2020 and `r2[.]mscode[.]pl` (2026)

Because the allocation dates from 2026, reputation tools describe the current holder, not the 2023 holder of the address, and I make **no attribution** to MSCode or to Poland. The two old executables and the earlier passive-DNS entries show that the address had other users long before 2023 and are not linked to this email. The corpus (section 7) is the better source for how the address was used in 2023. I reviewed the first 10 of the 59 passive-DNS records only.

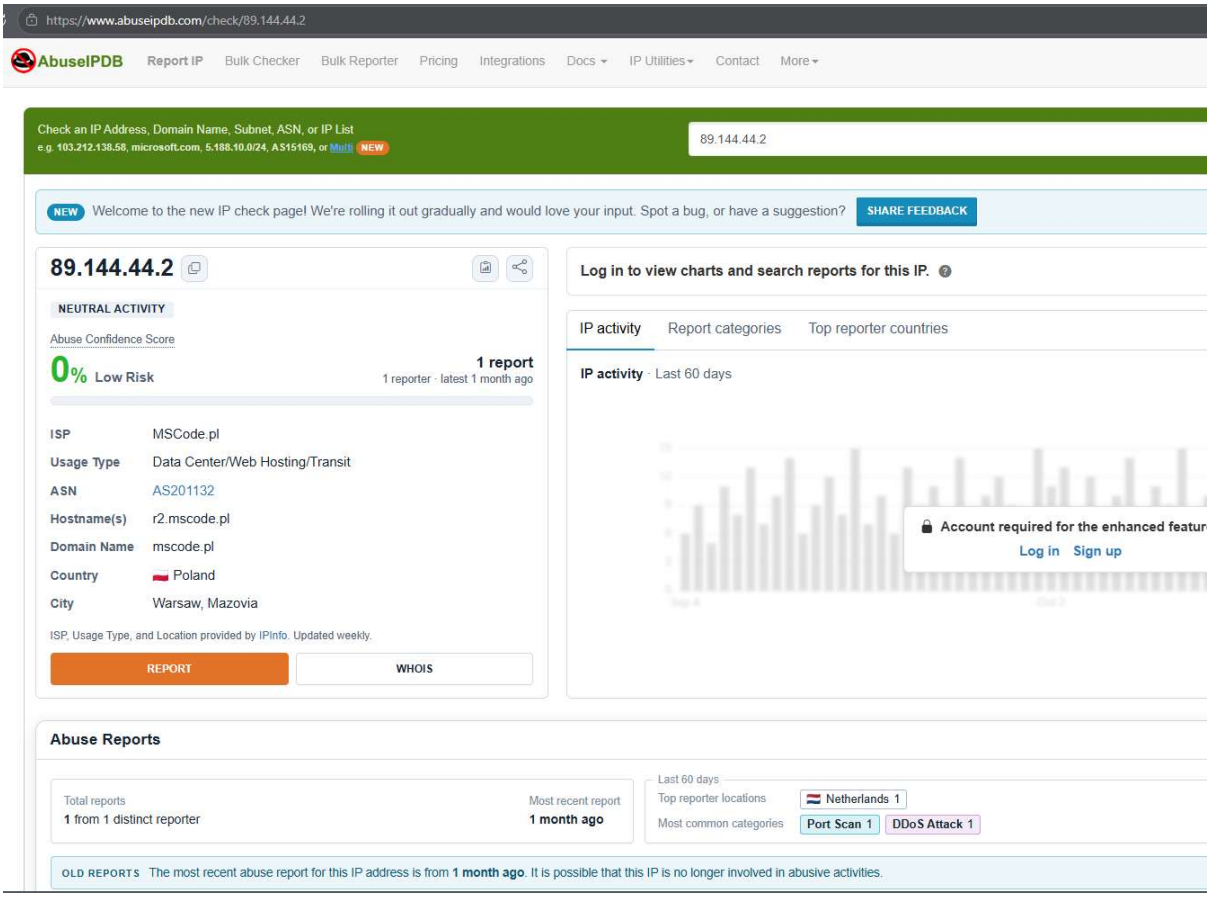


Figure 17. AbuseIPDB: 0% confidence, 1 report, MSCode.pl (AS201132).

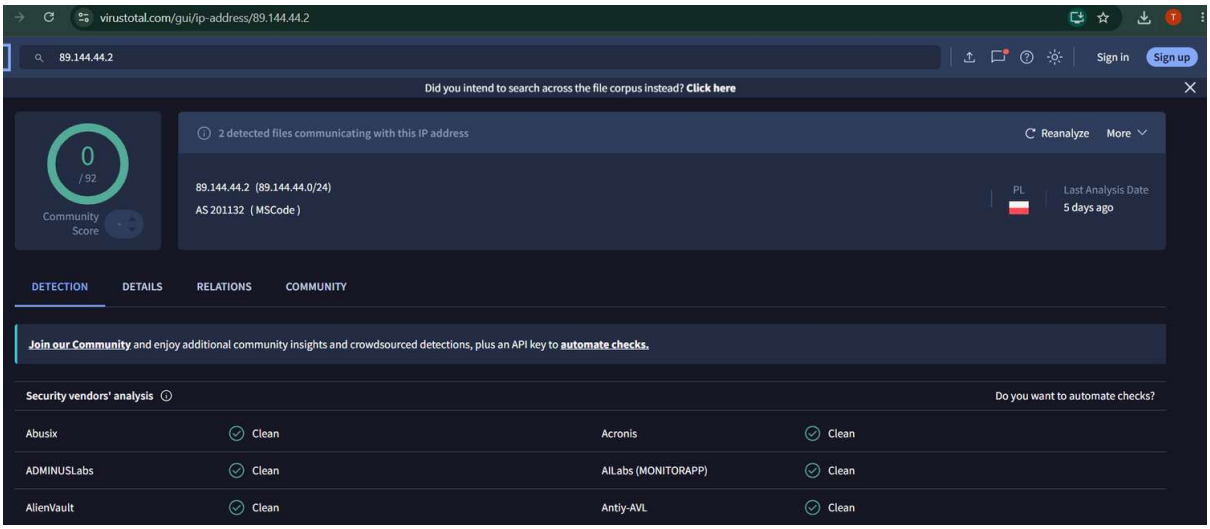


Figure 18. VirusTotal: 0/92 for 89[.]144[.]44[.]2, AS201132.

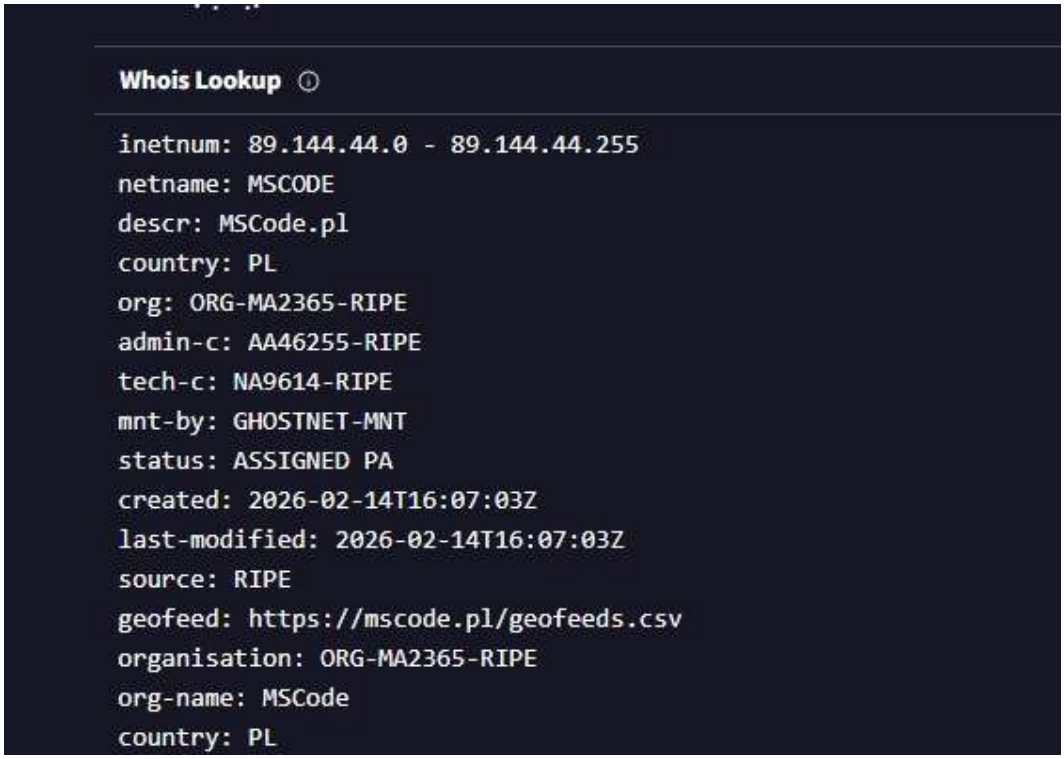


Figure 19. RIPE WHOIS (via VirusTotal): MSCode, allocation created 2026-02-14.

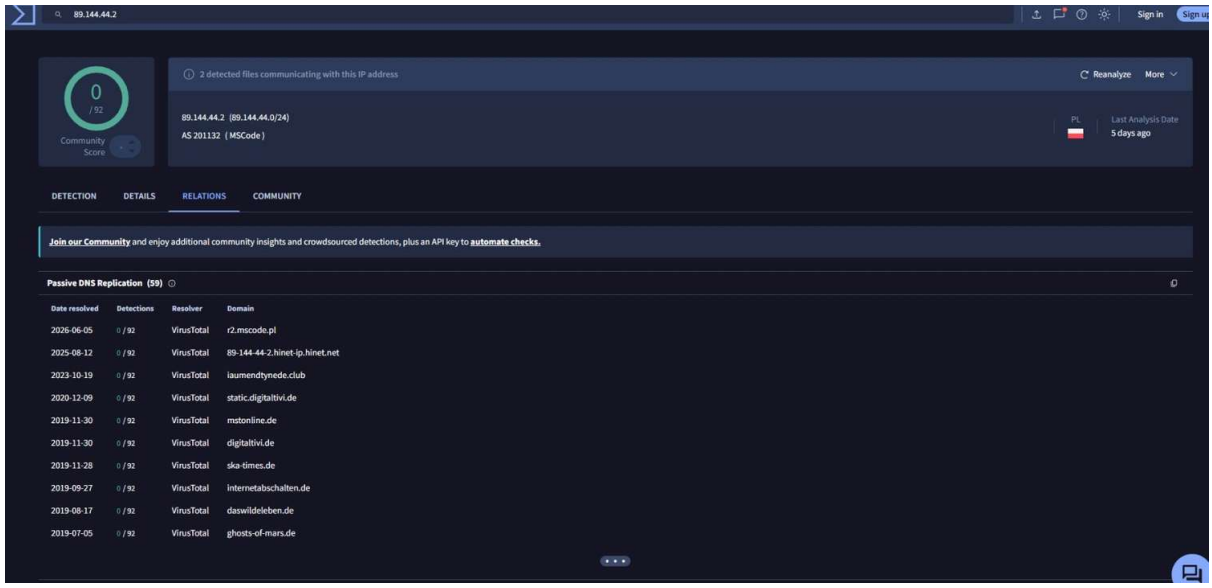


Figure 20. VirusTotal passive DNS for the IP (first 10 of 59 records).

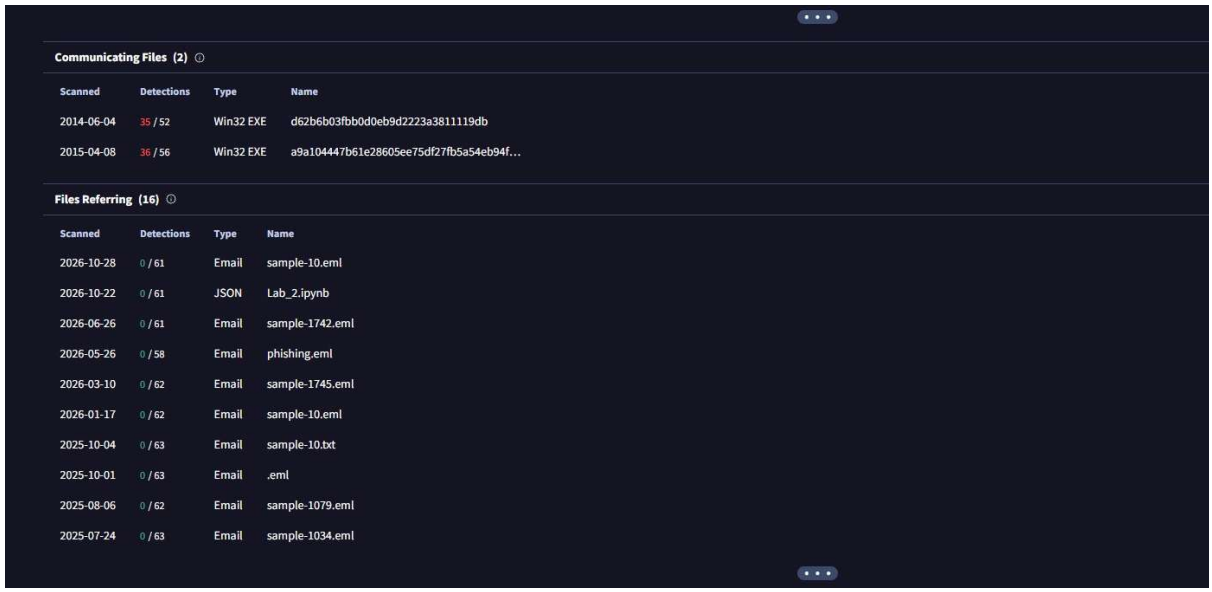


Figure 21. VirusTotal: two old communicating executables and files referring to the IP.

7. Campaign context (corpus pivot)

I searched the full phishing_pot corpus for the email's indicators. The IP count covers the headers only; the other three cover the whole message.

Indicator	Emails	Earliest	Latest	Also from the IP
89[.]144[.]44[.]2 (headers)	26	2023-05-25	2024-02-08	n/a
thebandalisty[.]com	217	2023-02-26	2024-02-14	11
sotrecognizd@gmail[.]com	56	2023-09-07	2024-01-30	3
access-accsecurity[.]com	108	2023-03-22	2023-09-18	9

- Of the 26 emails from the IP, 22 have parseable dates. The lures change over time: a fake Facebook login alert (May 2023), the Microsoft “unusual signin” template (July to September 2023, plus one in February 2024), then gift-card and rewards spam (October to December 2023).
- Nine emails from this IP use the Microsoft template with `access-accsecurity[.]com`, dated 4 July to 8 September 2023. This sample is the last of those nine.
- The Gmail callback address first appears in the corpus one day before this email.
- The tracking domain is in far more emails than the IP carries, so the infrastructure is wider than one sending address.

These counts describe how often an indicator appears in a public collection. They do not measure how many people were targeted.

```
┌──(kali㉿kali)-[~/phishing-investigation]
└─$ cd ~/phishing-investigation/phishing_pot/email
grep -l "89.144.44.2" *.eml | wc -l
for f in $(grep -l "89.144.44.2" *.eml); do echo "== $f"; grep -m1 -i '^Date:' "$f"; grep -m1 -i '^
26
== sample-10.eml
Date: Fri, 8 Sep 2023 05:47:04 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-706.eml
Date: Thu, 25 May 2023 07:47:06 +0000
From: "Facebook" <>
Subject: Someone tried to Iog in To Your Account, User lD : phishing@pot
== sample-867.eml
Date: Tue, 4 Jul 2023 12:31:34 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-907.eml
Date: Fri, 14 Jul 2023 20:04:05 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-960.eml
Date: Wed, 19 Jul 2023 04:26:19 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-987.eml
Date: Tue, 25 Jul 2023 20:04:10 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-1002.eml
Date: Wed, 26 Jul 2023 21:13:36 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-1031.eml
Date: Sun, 30 Jul 2023 22:28:38 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-1034.eml
Date: Thu, 27 Jul 2023 21:16:57 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-1079.eml
Date: Tue, 15 Aug 2023 08:22:49 +0000
From: Microsoft account team ,_<no-reply@access-accsecurity.com>
Subject: Microsoft account unusual signin activity
== sample-1646.eml
Date: Wed, 25 Oct 2023 21:36:00 +0000
From: Walgreens - Thank You!   ,_<0ydzn@rwoaknkm0f.com>
Subject: Confirmation Needed Act Now!
== sample-1689.eml
Date: Sat, 28 Oct 2023 05:32:28 +0000
From: WalMart    ,_<rxpzx@r3kd8s02e6.com>
Subject: You have won an $500 WalMart Gift Card
== sample-1717.eml
Date: Fri, 27 Oct 2023 09:50:07 +0000
From: Kohls    ,_<ayjqx@uc0e1bxaij.com>
Subject: 2nd attempt for phishing@pot
== sample-1742.eml
Date: Mon, 30 Oct 2023 23:04:32 +0000
From: CVS Pharmacy - Congratulations!  ,_<gendt@z1rz2zckjo.com>
Subject: hurry up ! Rewards have arrived!
== sample-1745.eml
Date: Thu, 2 Nov 2023 17:25:19 +0000
From: Facebook ,_<slp5o@gwu7nvb6l3.com>
Subject: Someone tried to Iog in To Your Account, User lD : phishing@pot
== sample-1801.eml
Date: Tue, 7 Nov 2023 01:39:08 +0000
From: Facebook ,_<3p0hw@zkcd2nkdgz.com>
Subject: Someone tried to Iog in To Your Account, User lD : phishing@pot
== sample-1884.eml
Date: 11-12-2023
From: Apple TV ,_<uoy4w@xfhe17b2ib.com>
Subject: phishing@pot, Please verify
== sample-1914.eml
```

Figure 22. Corpus emails containing 89.144.44.2 with date, sender and subject.

```
┌──(kali㉿kali)-[~/phishing-investigation/phishing_pot/email]
└─$ grep -l "thebandalisty" *.eml | wc -l
grep -l "sotrecognizd" *.eml | wc -l
grep -l "access-accsecurity" *.eml | wc -l
217
56
108
```

Figure 23. Corpus emails containing the tracking domain (217), Gmail address (56) and sender domain (108).

```
python3 ~/phishing-investigation/corpus_pivot.py
/home/kali/phishing-investigation/corpus_pivot.py:15: DeprecationWarning: 'maxsplit' is passed as positional ar
  hdr = re.split(r"\r?\n\r?\n", raw, 1)[0].lower()
indicator            files  earliest    latest
IP in headers           26  2023-05-25  2024-02-08
thebandalisty          217  2023-02-26  2024-02-14
sotrecognizd            56  2023-09-07  2024-01-30
access-accsecurity     108  2023-03-22  2023-09-18

IP and thebandalisty: 11 emails
IP and sotrecognizd: 3 emails
IP and access-accsecurity: 9 emails

2023-05-25 sample-706.eml                          Someone tried to Iog in To Your Accoun
2023-07-04 sample-867.eml                          Microsoft account unusual signin activ
2023-07-14 sample-907.eml                          Microsoft account unusual signin activ
2023-07-19 sample-960.eml                          Microsoft account unusual signin activ
2023-07-25 sample-987.eml                          Microsoft account unusual signin activ
2023-07-26 sample-1002.eml                         Microsoft account unusual signin activ
2023-07-27 sample-1034.eml                         Microsoft account unusual signin activ
2023-07-30 sample-1031.eml                         Microsoft account unusual signin activ
2023-08-15 sample-1079.eml                         Microsoft account unusual signin activ
2023-09-08 sample-10.eml                           Microsoft account unusual signin activ
2023-10-25 sample-1646.eml                         Confirmation Needed Act Now!
2023-10-27 sample-1717.eml                         2nd attempt for phishing@pot
2023-10-28 sample-1689.eml                         You have won an $500 WalMart Gift Card
2023-10-30 sample-1742.eml                         hurry up ! Rewards have arrived!
2023-11-02 sample-1745.eml                         Someone tried to Iog in To Your Accoun
2023-11-07 sample-1801.eml                         Someone tried to Iog in To Your Accoun
2023-11-11 sample-1914.eml                         🔥BLACK FRIDAY IS ON YO🔥 ! 🎁You have wo
2023-11-27 sample-1984.eml                         Final Notice Coming for a Keurig Coffe
2023-11-28 sample-2021.eml                         Congratulations! You have won an Stanl
2023-11-29 sample-2039.eml                         Congratulations - Details Apply
2023-11-30 sample-2040.eml                         Congratulations! You have won an Stanl
2024-02-08 sample-2818.eml                         Microsoft account unusual signin activ
None       sample-2156.eml                         CONGRATS....Your Hilton Reward Has Arr
None       sample-1884.eml                         phishing@pot, Please verify
None       sample-2061.eml                         Congratulations! You have won an Stanl
None       sample-2099.eml                         Hurry Up!! You Could Win! See Inside t

┌──(kali㉿kali)-[~/phishing-investigation/phishing_pot/email]
└─$
```

Figure 24. Pivot script summary: indicator counts, date ranges, overlap with the IP.

8. Indicators of compromise (defanged)

Type	Indicator	Context	Verdict
Domain	`access-accsecurity[.]com`	From domain, lookalike of a Microsoft sender; registration timing unresolved	Suspicious (VT 0/92)
Domain	`thcultarfdes[.]co[.]uk`	Return-Path and sending host; not registered as of 2026-10-27	Suspicious (SPF none; VT 0/92)

Type	Indicator	Context	Verdict
IP	89[.]144[.]44[.]2	Sending IP; in headers of 26 corpus samples (2023-05 to 2024-02)	Malicious sender
Email	no-reply@access-accsecurity[.]com	From address	Suspicious
Email	bounce@thcultarfdes[.]co[.]uk	Return-Path	Suspicious
Email	sotrecognizd@gmail[.]com	Reply-To and all mailto links	Suspicious
Subject	Microsoft account unusual signin activity	Email subject	Suspicious
Domain	thebandalisty[.]com	Tracking pixel host; created 2023-02-21; VT 9/92	Malicious
URL	hxxp://thebandalisty[.]com/track/o43062rdzGz18708448Gdrw1821750fYo33632dSjh176	Hidden 1x1 tracking pixel	Malicious
IP	44[.]194[.]110[.]133 34[.]193[.]241[.]188	Observed DNS records of the From domain (AWS); attribution unconfirmed	Unconfirmed

The full list with sources is in `iocs.csv`.

9. MITRE ATT&CK mapping

Technique	Basis
T1566 Phishing	Delivery by email. There is no attachment and no link to a malicious site, so I use the parent technique and not a sub-technique
T1598 Phishing for Information (candidate)	The lure pushes the victim to contact the attacker; the goal is inferred, not observed
T1656 Impersonation	Spoofed Microsoft sender identity
T1583.001 Acquire Infrastructure: Domains	Lookalike and tracking domains
T1585.002 Establish Accounts: Email Accounts	Attacker-controlled Gmail address

The tracking pixel and the filler text do not map cleanly to a technique and are described in words in section 5.

10. Response and detection

Response actions

1. Block the domains, sending IP and Gmail address from section 8 at the mail gateway.
2. Block `thebandalisty[.]com` at DNS and the proxy, and search proxy logs for requests to it to find anyone whose client loaded the pixel.
3. Search all mailboxes for the subject and sender, and purge any matches.
4. If a user replied to the Gmail address, treat it as possible information disclosure: reset their credentials and review their sign-in activity.
5. Notify users, and report the domains to the registrars' abuse contacts (NameCheap and NameBright).

Detection ideas

- From display name contains "Microsoft" while the sender domain is not a Microsoft domain.
- Reply-To is a free-mail address and differs from the From domain.
- SPF none or fail together with DMARC not pass.
- A hidden 1x1 or `visibility:hidden` remote image in an email.
- `mailto:` links in the body pointing to free-mail addresses.
- A message body made up largely of unrelated word lists.

11. Limitations

- All lookups were made more than three years after the email. The three domains are unregistered or parked, so most 2023 registration and DNS data could not be recovered.
- No vendor flags `access-accsecurity[.]com`, `thcultarfdes[.]co[.]uk` or the sending IP (0/92 each). The case against them rests on the headers and the corpus, not on reputation feeds.
- The registration timing of `access-accsecurity[.]com` is unresolved (section 6.1).
- The 2023 holder of `89[.]144[.]44[.]2` is unknown. No attribution is made.
- Corpus counts and `Date:` headers come from a public collection; I verified dates against Microsoft timestamps for three samples only.
- Only the first 10 of 59 passive-DNS records for the IP were reviewed, and only the end of the body was inspected for filler text.
- Nothing was visited, detonated or run in a sandbox, and no urlscan.io analysis was done, so no landing page or payload was analysed.
- A search-result snippet suggested a Microsoft Q&A post from February 2023 mentioning the tracking pixel URL. I could not verify it, so it is not used as evidence.

12. Evidence in the repository

- `screenshots/`: the analysis screenshots shown as figures in this report
- `iocs.csv`: indicator list with context and verdicts
- `headers/sample-10-headers.txt`: the email's header section